

universidade de aveiro



estga

escola superior de
tecnologia e gestão
de água

Vulnerabilidades em Redes TCP/IP

Segurança em Redes e Sistemas Informáticos

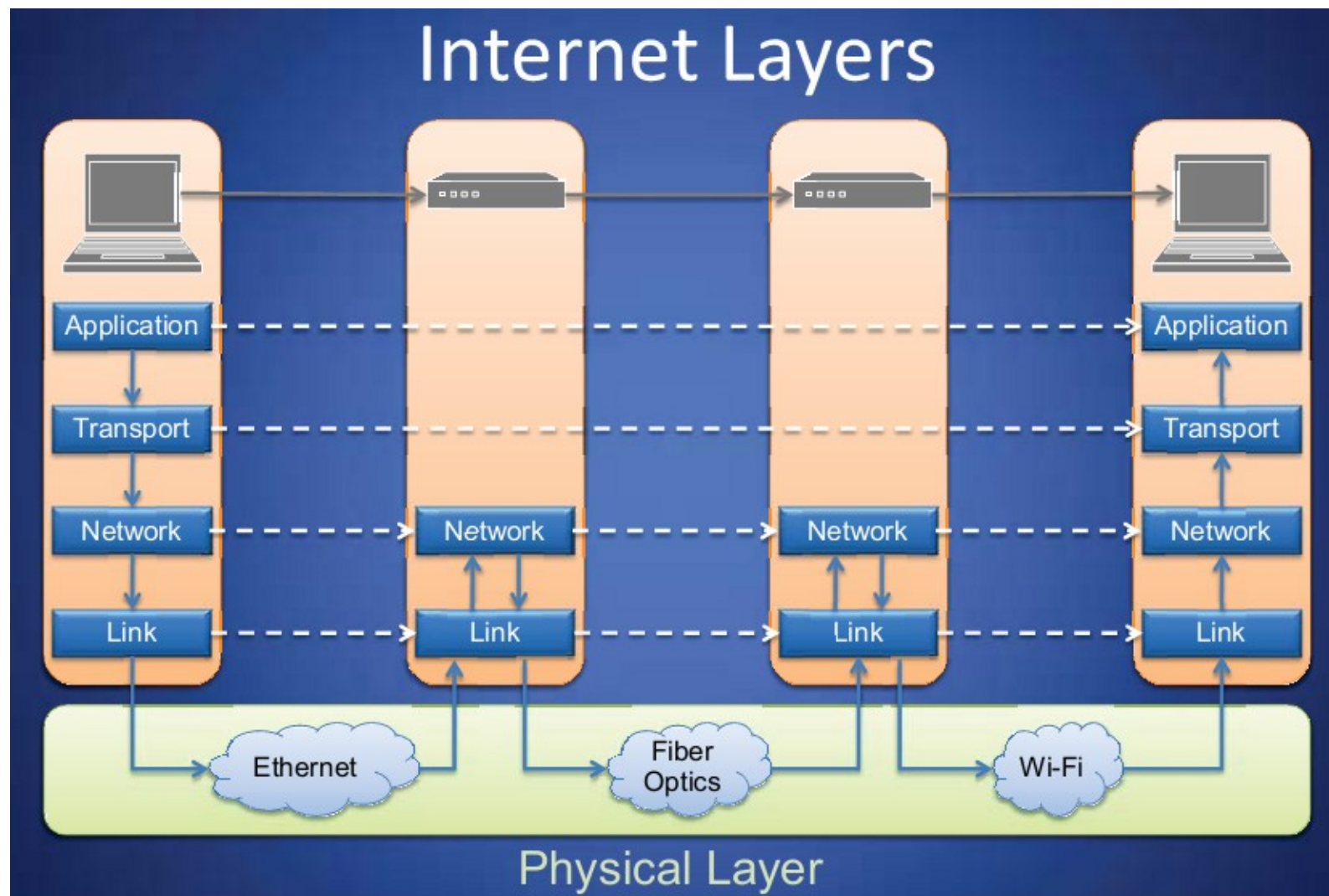
CTeSP em Redes e Sistemas Informáticos

Escola Superior de Tecnologia e Gestão de Águeda

Universidade de Aveiro

2025-26

Pilha Protocolar TCP/IP



Nível Físico

- ▶ Hubs
 - ▶ Informação em difusão
 - ▶ Ameaça: Fuga de informação (*sniffers*)
- ▶ *Sniffers*
 - ▶ Placas de rede funcionam normalmente em modo não promíscuo
 - ▶ Apenas escutam o que é enviado para o seu MAC
 - ▶ *Sniffers* operam em modo promíscuo
 - ▶ Leem *frames* com qualquer MAC



Camada Física (Nível 1)

- ▶ Salvaguardas contra sniffers:
 - Impedir a utilização de placas em modo promíscuo
 - Utilização de switches
 - Cifra do tráfego
- ▶ Detetores de sniffers
 - Antisniff (<http://packetstormsecurity.org/sniffers/antisniff>)



Camada de Ligação (Nível 2): Switches

- ▶ Os switches só enviam dados para o destinatário
- ▶ Constroem uma tabela com os endereços MAC das máquinas em cada porta
- ▶ Quando uma trama chega a um switch:
 - ▶ Procura a porta onde está o dispositivo com o MAC a que a trama se destina
 - ▶ Envia a trama por essa porta
- ▶ Reduzem o problema do *sniffing*
 - ▶ Uma placa de rede só vê o tráfego que lhe é destinado



Protocolo ARP (1)

- ▶ **Address Resolution Protocol (ARP)**
 - ▶ Traduz endereços IP para endereços MAC
- ▶ **ARP Query**
 - ▶ Uma máquina questiona se existe na rede uma máquina com um determinado endereço IP e qual o correspondente endereço MAC.
 - ▶ Quem tem o endereço 192.168.43.25? Responda a 192.168.43.1
- ▶ **ARP Reply**
 - ▶ Resposta ao pedido de ARP (ARP Query), normalmente enviada apenas para quem fez o pedido
 - ▶ O endereço 192.168.43.25 está em 56:EF:CD:AB:12:34
 - ▶ Associa um endereço MAC a um endereço IP
- ▶ **Respostas ARP não solicitadas (gratuitous ARP)**
 - ▶ Enviadas por máquinas quando se ligam
 - ▶ Não são enviadas em resposta a nenhum pedido
 - ▶ Associa um endereço MAC a um endereço IP

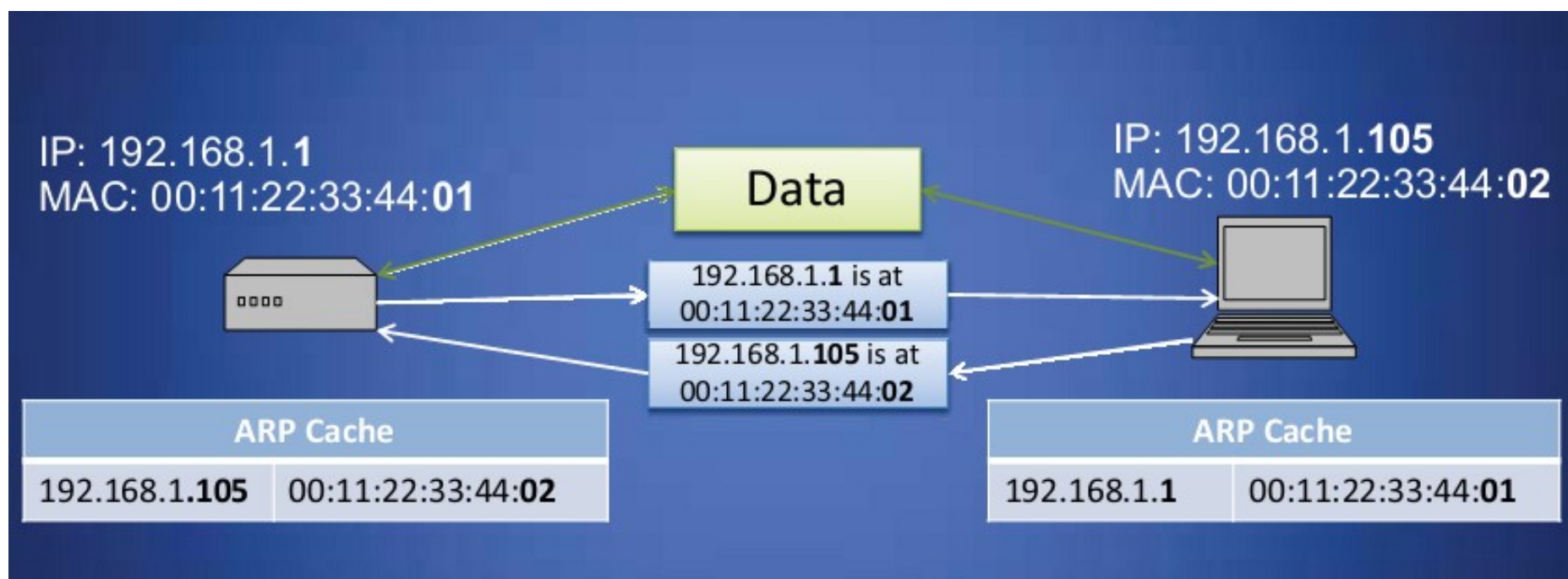


Protocolo ARP (2)

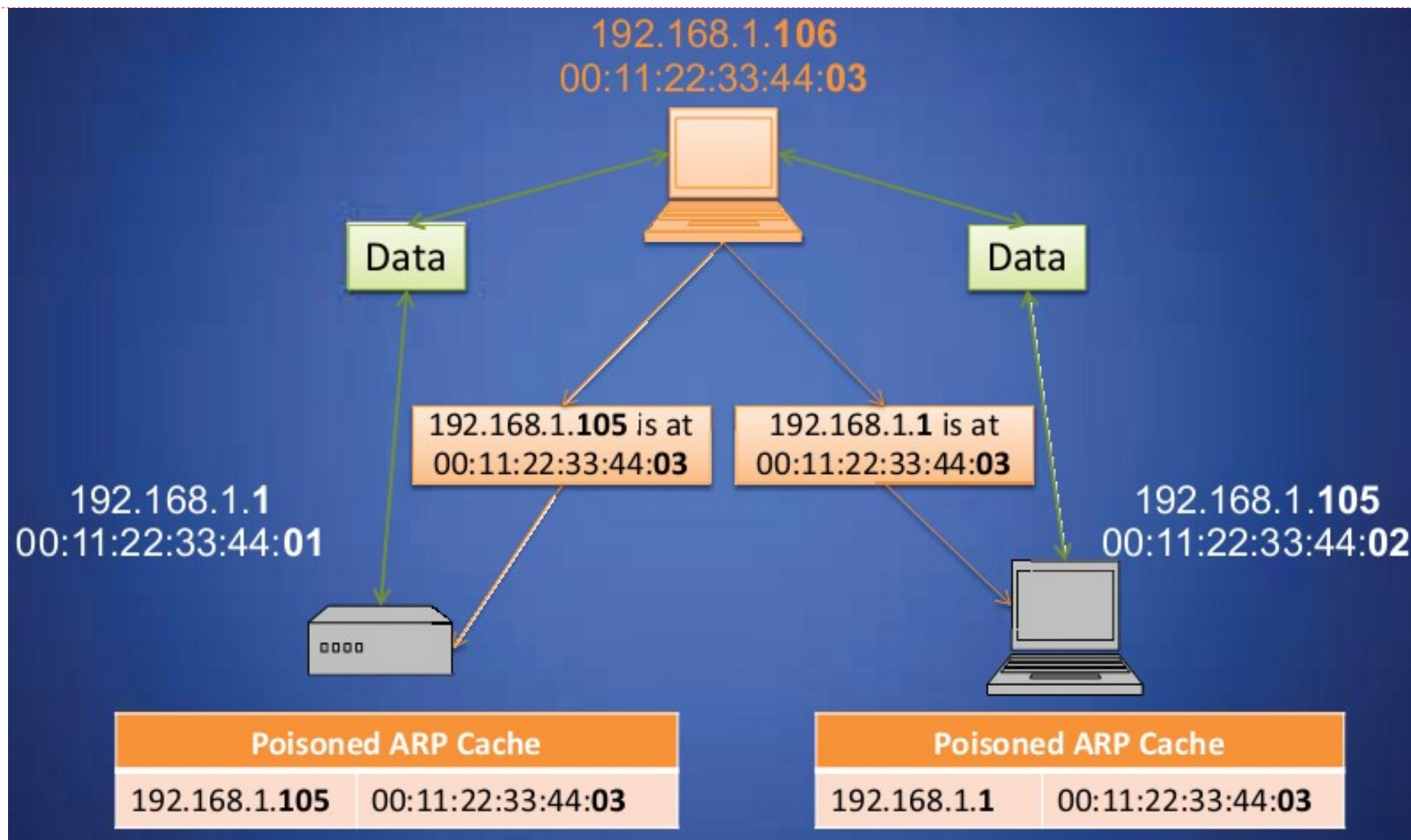
- ▶ Tabela de ARP (*ARP caches*)
 - ▶ Cada máquina regista a informação de ARP recebida na sua tabela de ARP
 - ▶ As entradas na tabela de ARP têm um tempo de vida, ao fim do qual são removidas
- ▶ ARP *spoofing*
 - ▶ Mensagens de ARP com informação falsa
 - Falsa associação entre endereço IP e endereço MAC
 - ▶ Respostas ARP não contêm assinatura pelo que é fácil personificar um MAC
- ▶ ARP *Poisoning*
 - ▶ O que acontece se uma máquina responder a um ARP Query com a informação errada?
 - ▶ O que acontece se uma máquina enviar ARP gratuitos com informação errada?
 - ▶ A tabela de ARP fica com informação errada. Fica envenenada (*ARP Poisoning*)
 - ▶ Um atacante pode fazer um envenenamento para implementar um ataque Man-In-the-Middle (MitM)



Tabelas de ARP corretas



Tabelas de ARP envenenadas



Internet Control Message Protocol

- ▶ *Internet Control Message Protocol (ICMP)*
 - ▶ Utilizado para testar a rede e para *debug*
 - ▶ Mensagem simples encapsulada num único pacote IP
- ▶ Ferramentas baseadas no ICMP
 - ▶ Ping: envia séries de mensagens “Echo Request” e fornece estatísticas dos tempos de viagem, ida e volta (*round trip*), e de perda de pacotes
 - ▶ Traceroute: envia séries de mensagens ICMP com valores incrementais de TTL (*Time To Live*) para descobrir rotas



Ataques ICMP

- ▶ Ping of Death

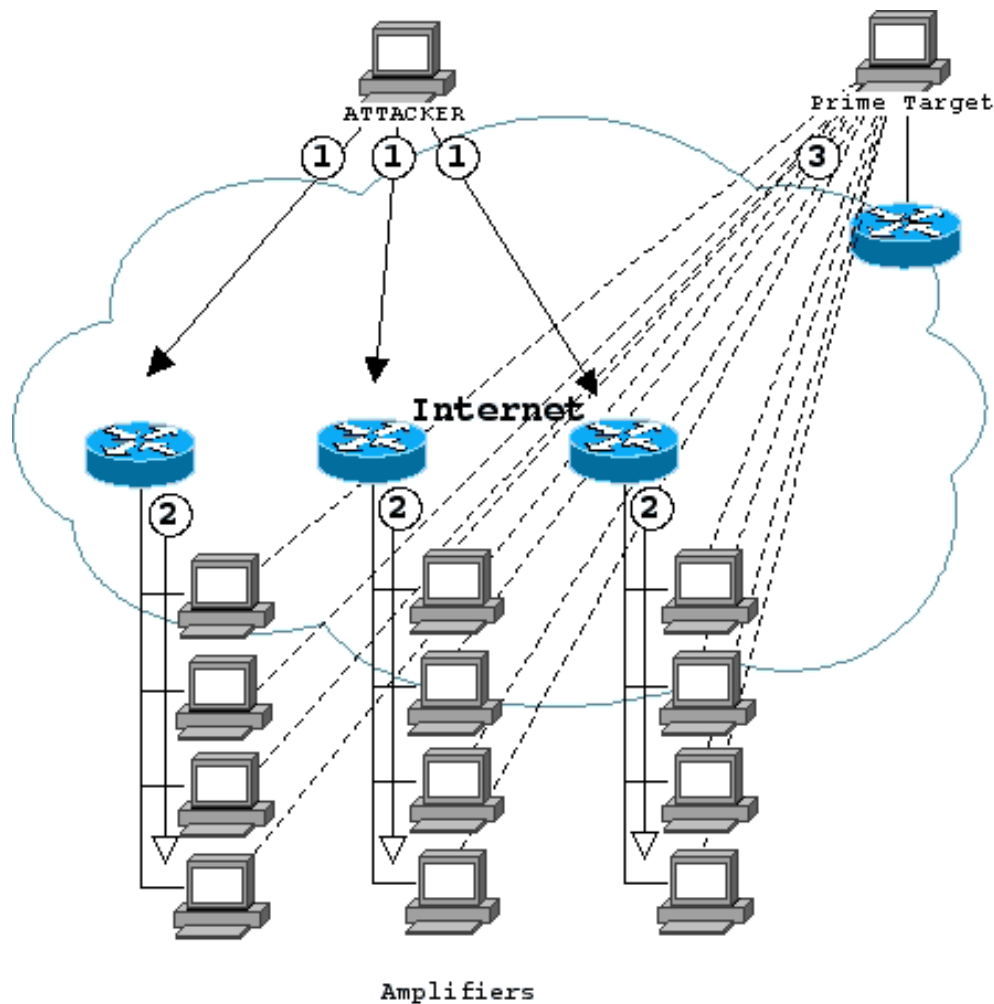
- ▶ Mensagem ICMP excessivamente grande e usando fragmentação IP
- ▶ O pacote reconstruído provocava o crash de vários sistemas operativos devido a *buffer overflow*.
- ▶ Não é um problema exclusivo de ICMP
 - ▶ É da reconstrução de pacotes IP fragmentados

- ▶ Smurf

- ▶ Ping para endereços de rede de difusão (*broadcast*) utilizando um endereço de origem falsificado
- ▶ O router da rede de destino encaminha o pacote para todas as máquinas da rede
 - ▶ Todas vão responder: efeito de amplificação
- ▶ O endereço de origem falsificado é o endereço da vítima



Ataques ICMP: Smurf Attack



Vulnerabilidades IP (1)

- ▶ Transmissão não é cifrada
 - ▶ Escutas (*eavesdropping*) possível em todos os nós do caminho
- ▶ Não há autenticação da origem (*source*) nem verificação da integridade dos pacotes (permite IP *spoofing*)
 - ▶ Quem envia pode falsificar o endereço de origem, tornando difícil fazer o *trace* do pacote até ao atacante
 - ▶ Perigoso basear políticas de controlo de acesso nos endereços IP
 - ▶ Todo o pacote, cabeçalho (*header*) e corpo (*payload*) pode ser modificado enquanto em transito para o destino
 - ▶ Permite: falsificação do conteúdo, redireccionamentos e ataques man-in-the-middle



Vulnerabilidades IP (2)

- ▶ Não há restrições de largura de banda
 - ▶ Grande número de pacotes pode ser colocado na rede para um ataque de negação de serviço
 - ▶ Endereços de difusão (*broadcast*) permitem a amplificação de tráfego
- ▶ Segurança das atualizações das rotas
 - ▶ Um atacante pode corromper as tabelas de *routing* enviando actualizações de *routing*
 - ▶ RIPv1 e BGP não possuem autenticação
 - ▶ Pacotes ICMP redirect

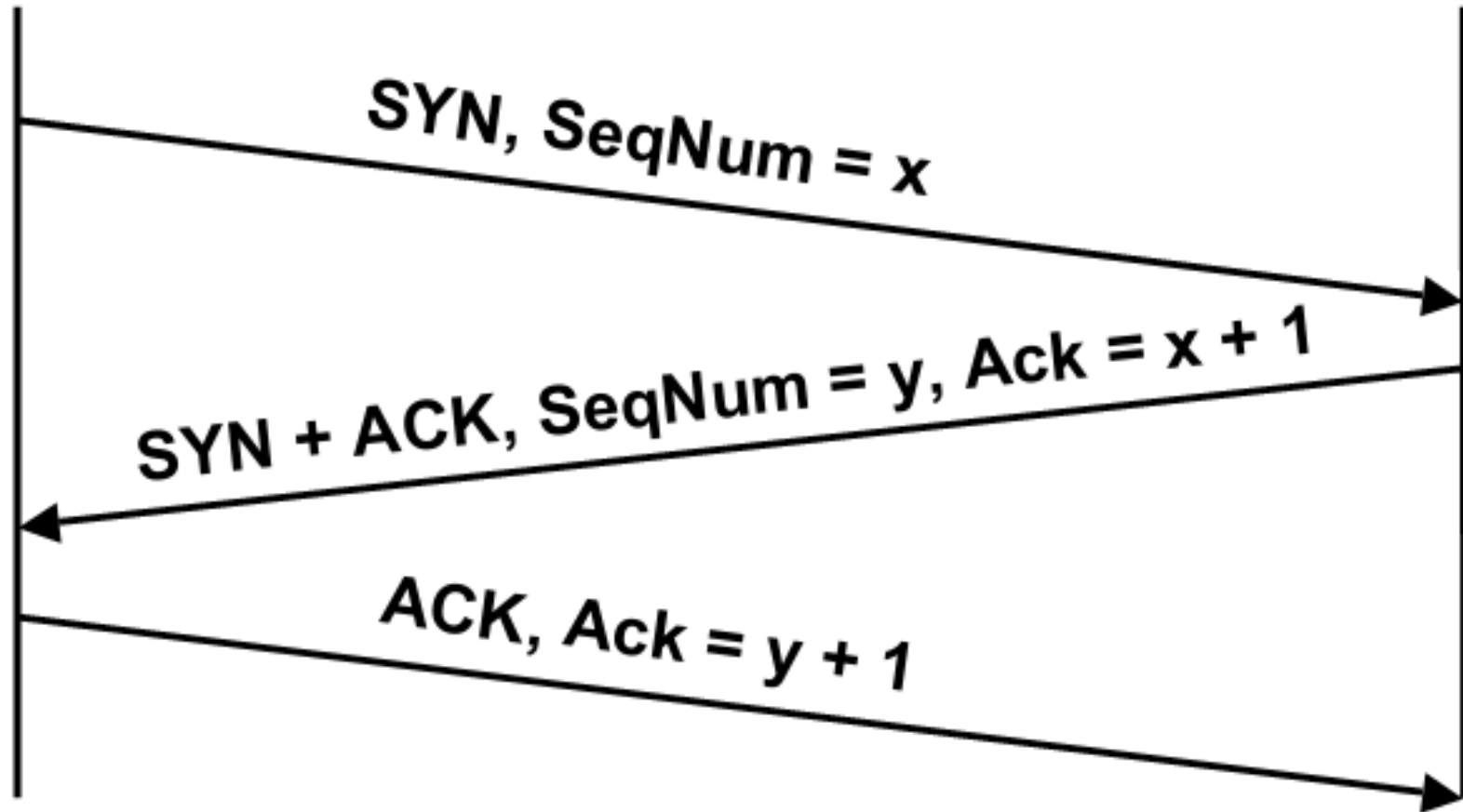


Camada de Transporte (Nível 4): TCP

- ▶ **Transmission Control Protocol (TCP)**
 - ▶ Protocolo da camada de transporte com garantida da entrega das mensagens e que permite o endereçamento de aplicações numa mesma máquina (portos)
 - ▶ Garante a entrega ordenada, marcando cada pacote com um número de sequência
 - ▶ Sempre que um pacote é recebido com sucesso é gerada uma mensagem de confirmação (ACK)
 - ▶ Utiliza checksums para a verificação da integridade dos dados nos pacotes.



Nível 4: Estabelecimento de Ligação TCP

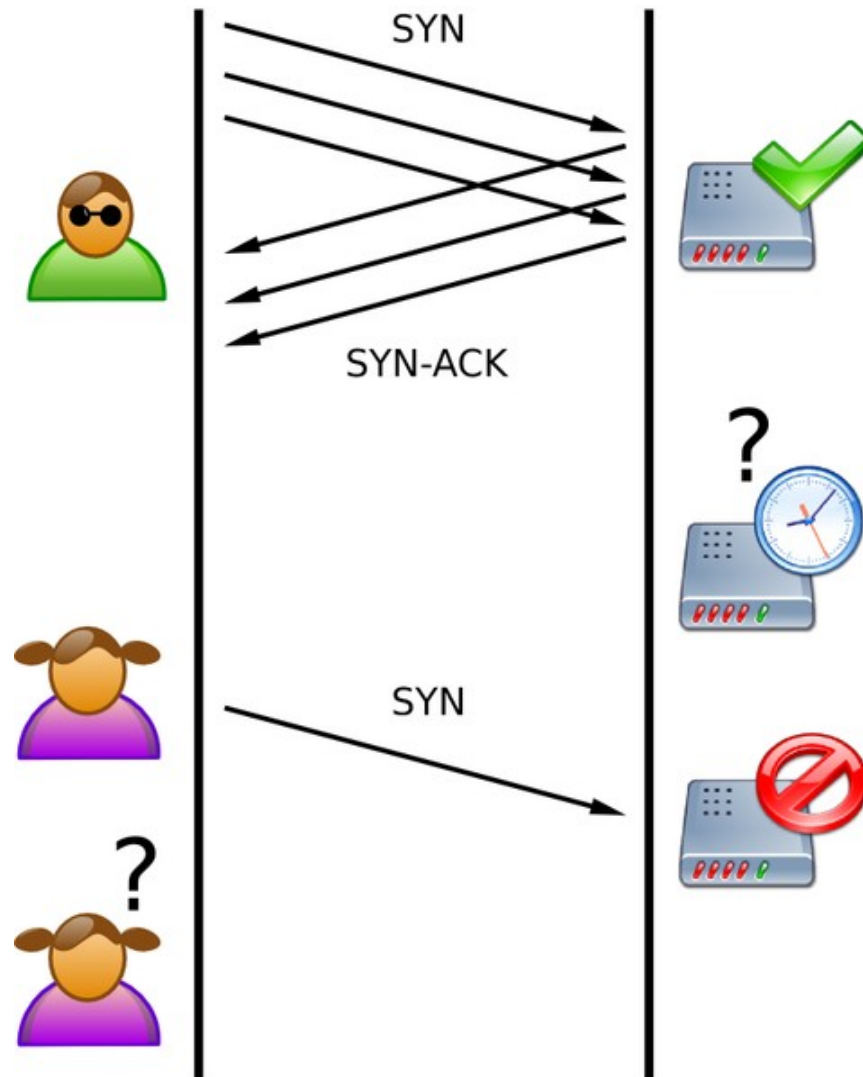


Ataque à Prestação de Serviços (SYN Flooding)

- ▶ Afoga um servidor com pedidos incompletos de ligação TCP/IP
 - ▶ O atacante normalmente usa IP spoofing
- ▶ Vulnerabilidades exploradas:
 - ▶ Não existe autenticação dos segmentos SYN
 - ▶ O servidor reserva mais recursos que o cliente
- ▶ Impacto na máquina atacada
 - ▶ Manutenção de pedidos de ligação até os eliminar por time-out
 - ▶ Reenvio periódico do segmento SYN+ACK
 - ▶ Os pedidos de ligação por cada porto são limitados
 - ▶ Os pedidos excedentes são rejeitados
 - ▶ Pedidos legítimos podem ser preteridos



Syn Flooding



SYN Flooding

- ▶ Não há solução definitiva
- ▶ Alteração do TCP dos servidores
 - ▶ Maiores filas de pedidos, menores time-outs
 - ▶ *Random Drop*
 - ▶ *SYN cookies*
 - ▶ Número de sequência inicial (ISN) é enviado cifrado no SYN+ACK (*cookie*)
 - ▶ E devolvido no ACK
 - ▶ O servidor não mantém nenhuma informação
- ▶ Colaboração de Firewalls
- ▶ Detetores de ataques



CVE (*Common Vulnerabilities and Exposures*)

<https://cve.mitre.org/>

- ▶ Dicionário público de vulnerabilidades e exposições de segurança
 - ▶ Para gestão de vulnerabilidades
 - ▶ Para gestão de correções (*patches*)
 - ▶ Para alarmística de vulnerabilidades
 - ▶ Para deteção de intrusões
- ▶ Fornece uma linguagem comum para referir problemas
 - ▶ Com base em identificadores
 - ▶ Formato: CVE-Ano-Índice



Vulnerabilidade e Exposição (CVE)

- ▶ **Vulnerabilidade: Erro no software**
 - ▶ Pode ser usado diretamente por um atacante para ganhar acesso ao sistema ou à rede
 - ▶ Um erro só é uma vulnerabilidade se permitir que o atacante viole uma política de segurança
- ▶ **Exposição: Problema que não compromete diretamente um sistema ou rede**
 - ▶ Mas permite aceder a informação ou capacidades que podem auxiliar um atacante
 - ▶ Pode ser um componente importante para o sucesso de um ataque



CVE: Exemplo

CVE-ID	
CVE-2016-6515	Learn more at National Vulnerability Database (NVD) • Severity Rating • Fix Information • Vulnerable Software Versions • SCAP Mappings
Description	
The <code>auth_password</code> function in <code>auth-passwd.c</code> in <code>sshd</code> in OpenSSH before 7.3 does not limit password lengths for password authentication, which allows remote attackers to cause a denial of service (crypt CPU consumption) via a long string.	
References	
Note: References are provided for the convenience of the reader to help distinguish between vulnerabilities. The list is not intended to be complete.	
• MLIST:[oss-security] 20160801 Announce: OpenSSH 7.3 released • URL:http://openwall.com/lists/oss-security/2016/08/01/2 • CONFIRM:https://github.com/openssh/openssh-portable/commit/fcd135c9df440bcd2d5870405ad3311743d78d97 • FEDORA:FEDORA-2016-4a3debc3a6 • URL:https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/X2L6RW34VFNXYNVVN2CN73YAGJ5VMTFU/	
Date Entry Created	
20160801	Disclaimer: The entry creation date may reflect when the CVE-ID was allocated or reserved, and does not necessarily indicate when this vulnerability was discovered, shared with the affected vendor, publicly disclosed, or updated in CVE.
Phase (Legacy)	
Assigned (20160801)	
Votes (Legacy)	
Comments (Legacy)	
Proposed (Legacy)	
N/A	
This is an entry on the CVE list , which standardizes names for security problems.	
SEARCH CVE USING KEYWORDS: Submit	
You can also search by reference using the CVE Reference Maps .	
For More Information: cve@mitre.org	

CVE e Ataques

Ataques podem ser compostos/possibilitados por várias vulnerabilidades

- Um CVE para cada vulnerabilidade
- Pode necessitar de uma sequência de vulnerabilidades
- Pode necessitar de uma das vulnerabilidades



Exemplo: Stagefright (Android, videos em mensagens MMS)

- CVE-2015-1538, P0006, Google Stagefright 'stsc' MP4 Atom Integer Overflow Remote Code Execution
- CVE-2015-1538, P0004, Google Stagefright 'ctts' MP4 Atom Integer Overflow Remote Code Execution
- CVE-2015-1538, P0004, Google Stagefright 'stts' MP4 Atom Integer Overflow Remote Code Execution
- CVE-2015-1538, P0004, Google Stagefright 'stss' MP4 Atom Integer Overflow Remote Code Execution
- CVE-2015-1539, P0007, Google Stagefright 'esds' MP4 Atom Integer Underflow Remote Code Execution
- CVE-2015-3827, P0008, Google Stagefright 'covr' MP4 Atom Integer Underflow Remote Code Execution
- CVE-2015-3826, P0009, Google Stagefright 3GPP Metadata Buffer Overread
- CVE-2015-3828, P0010, Google Stagefright 3GPP Integer Underflow Remote Code Execution
- CVE-2015-3824, P0011, Google Stagefright 'tx3g' MP4 Atom Integer Overflow Remote Code Execution
- CVE-2015-3829, P0012, Google Stagefright 'covr' MP4 Atom Integer Overflow Remote Code Execution



Prontidão (*security readiness*)

- ▶ As ameaças em redes de computadores são diferentes de outros tipos de ameaças
 - ▶ Os ataques podem ser lançados em qual hora, de qualquer local
 - ▶ Podem ser facilmente coordenados
 - ▶ e.g. Distributed Denial of Service attacks (DDoS)
 - ▶ São baratos
 - ▶ Podem ser automatizados
 - ▶ São rápidos
- ▶ Requerem uma capacidade permanente (24x7) de reação a ataques:
 - ▶ Equipas de especialistas em segurança
 - ▶ CERT (Computer Emergency Response Team)
 - CERT.PT
 - ▶ CSIRT (Computer Security Incident Response Team)
 - ▶ Alertas de ataque na hora
 - ▶ Teste e avaliação dos níveis de segurança existentes
 - ▶ Procedimentos de reação expeditos



CERT.PT

[Coordenação da Resposta a Incidentes](#)

[Suporte On-site](#)

[Capacitação CSIRT](#)

[Alertas de Segurança](#)

[RFC 2350](#)

[Início](#) [CERT.PT](#)

CERT.PT

O CERT.PT é um serviço integrante do CNCS que coordena a resposta a incidentes envolvendo entidades do Estado, operadores de serviços essenciais, operadores de Infraestruturas Críticas nacionais e prestadores de serviços digitais. De forma geral, estamos a falar do ciberespaço nacional, incluindo qualquer dispositivo pertencente a uma rede ou bloco de endereçamento atribuído a um operador de comunicações eletrónicas, instituição, pessoa coletiva ou singular com sede em território Português, ou que esteja fisicamente localizado em território Português.

Aconselhamos o uso da nossa chave PGP (Pretty Good Privacy) disponível [aqui](#).

Informação técnica sobre o serviço CERT.PT está disponível no [RFC2350](#).

O CERT.PT é membro da Rede Nacional de CSIRT e representante nacional na Rede Europeia de CSIRT, estabelecida pela Diretiva (EU) 2016/1148 (Diretiva SRI).

O CERT.PT é membro acreditado do Trusted Introducer e Full Member do Forum of Incident Response and Security Teams (FIRST).



<https://www.cncs.gov.pt/certpt/>

Rede Nacional CSIRT



OBJETIVOS

- Estabelecer laços de confiança entre elementos responsáveis pela segurança informática de forma a criar um ambiente de cooperação e assistência mútua no tratamento de incidentes e na partilha de boas práticas de segurança;
- Criar indicadores e informação estatística nacional sobre incidentes de segurança com vista à melhor identificação de contra-medidas pró-activas e reactivas;
- Criar os instrumentos necessários à prevenção e resposta rápida num cenário de incidente de grande dimensão;
- Promover uma cultura de segurança em Portugal.



CSIRT@UA



universidade de aveiro
theoria poiesis praxis

SOBRE A UA

ESTUDAR

VIVER

INVESTIGAR

COOPERAR

INTERNACIONAL

📄 | EN | 🔍

cibersegurança

acerca

alertas

csirt@ua

contactos

UA / ciberseguranca / CSIRT@UA / Missão

Missão

O CSIRT@UA tem como missão assegurar um serviço de resposta a incidentes de segurança informática, nomeadamente através da gestão do processo de resposta a incidentes de segurança e articulação da resposta com os interlocutores internos e externos.

<https://www.ua.pt/pt/ciberseguranca/csirt-missao>





Questões?

Hélder Gomes (helder.gomes@ua.pt)